

Data Retention and Disposal Policy

Organization: Techno Optics LLC (operating Taxottic) **Document version:** 1.0 **Effective date:** 2026-05-04
Owner: Information Security Lead, Techno Optics LLC **Review cadence:** Annually, and after any material change to the data model or to applicable law

1. Purpose

This Data Retention and Disposal Policy ("Policy") defines how long Techno Optics LLC retains customer data in the Taxottic application, the conditions that trigger disposal, and the methods used to dispose of data so that it cannot be reconstructed. It implements the retention commitments made in our Privacy Policy (<https://taxottic.com/legal/privacy>) and gives operations personnel a clear, auditable rule for every category of data we process.

The Policy applies to all production data — including data we hold on behalf of consumers who use Taxottic via the Plaid Link integration — and to all backups, exports, and derived datasets produced from that production data.

2. Scope

This Policy covers:

- The Taxottic application database operated by Supabase (Postgres, AWS us-east-1).
- Encrypted backups of that database held by Supabase.
- Object storage for user-uploaded prior-year tax documents (Supabase Storage, AWS us-east-1).
- Banking data ingested from Plaid (account metadata, transactions, access tokens).
- Application logs and error-tracking data held by Vercel and Supabase.
- Account-management records held in Stripe (billing) and the customer-support inbox.

Public marketing-site analytics, which contain no identifiers, are out of scope.

3. Guiding Principles

1. **Data minimisation.** We only collect data we need to forecast taxes, run the account, or comply with law. We do not buy data about users.
2. **Defined retention.** Every category of personal data has a maximum retention period set in the schedule below. There is no "indefinite" retention of personal data.

3. **Right to be forgotten.** A user may request account deletion at any time. Deletion is propagated to backups within the backup-retention window (see §6).
4. **Defensible disposal.** Disposal uses cryptographic deletion or overwrite methods that make data unrecoverable through commercially reasonable means.
5. **Legal hold.** Retention may be extended for specific records under a documented legal hold; the hold is logged and removed once the obligation is satisfied.

4. Retention Schedule

The following schedule binds the operations team. Periods begin on the trigger event listed in the right-most column.

Data category	Retention period	Trigger / start of clock
Account profile (email, name, photo, tax profile)	Life of account + 30 days in production, 90 days in backups	Account deletion request
Income and expense entries you log	Life of account + 30 days in production, 90 days in backups	Account deletion request, or earlier if user deletes the entry
Bank connection metadata (institution name, last-four mask, item ID)	Until disconnection + 30 days in production, 90 days in backups	User disconnects the bank, or account deletion
Plaid access tokens (encrypted with AES-256-GCM at rest)	Until disconnection + 0 days (revoked and rotated to NULL on disconnection)	Disconnect event from Plaid or user
Plaid transactions (per-transaction merchant, amount, date)	Until disconnection or 24 months from posted date, whichever is shorter, then archived in user-controlled exports only	Per-transaction posted date
Schedule C exports and tax reports the user generated	7 years from the relevant tax year (IRS guidance) unless the user deletes them sooner	Date the export was generated
Bella (in-app guide) conversations	12 months from last message, then deleted from production	Last message in the thread
Authentication audit log (sign-ins, passkey enrolments, MFA events)	12 months in production, 24 months in encrypted cold storage	Event timestamp
Application and security logs (Vercel, Supabase)	30 days in production, 90 days in encrypted cold storage	Log line timestamp
Stripe billing records (subscriptions, invoices, payment-method tokens)	7 years (US tax-record retention)	Date of the financial event
Customer-support emails and inquiries (book/contact forms)	24 months from last reply	Last reply timestamp
Encrypted database backups	30 days rolling	Backup creation
De-identified, aggregated analytics (no identifiers, no quasi-identifiers)	Indefinite	N/A

5. Disposal Methods

When the retention clock expires, or a user-initiated deletion is processed, data is disposed of using the methods below. The method depends on the medium.

- **Postgres production database (Supabase).** Records are removed via `DELETE` against the relevant table; row-level security and foreign-key cascades ensure that dependent rows are also removed. Tables that hold sensitive secrets (`bank_connection_secrets`) have row-level security with no policies, restricting access to the service role only — see migration `20260504000002_bank_token_encryption.sql`.
- **Object storage (Supabase Storage / S3).** Objects are removed via the storage API, which issues an immediate delete to the underlying S3 bucket. Bucket lifecycle rules permanently remove deleted-marker versions after 30 days.
- **Encrypted database backups.** Backups are managed by Supabase on a 30-day rolling window. After 30 days, the encryption key for that backup is destroyed; the ciphertext, once unkeyed, is unrecoverable (cryptographic erasure).
- **Plaid access tokens.** On disconnection, the token is set to `NULL` in `bank_connection_secrets` and Plaid's `/item/remove` endpoint is called to revoke it on Plaid's side. Even before disconnection, tokens in the database are encrypted with AES-256-GCM using a key held outside the database.
- **External vendors.** Stripe, Vercel, and Anthropic each apply their own deletion procedures when we issue a delete request through their APIs or support channels. We track each request and verify confirmation.
- **Local copies.** Personnel may not retain customer data on local devices. Any data pulled for debugging is held in a tmpfs-style scratch directory and is deleted on session close.

6. User-Initiated Deletion

A user may request account deletion at any time by emailing privacy@taxottic.com or by using the in-app delete-account control. On receipt:

1. We acknowledge the request within **2 business days**.
2. We complete production-database deletion within **30 days** of the request.
3. The deletion propagates to backups within **90 days** (the backup-retention window).
4. We notify the user once production deletion is complete and again once the backup window has closed.
5. We retain a minimal record of the request itself (timestamp, request type, requester email hash) for **24 months** so we can demonstrate the request was honoured. This record contains no other personal data.

7. Legal Hold

If a record is subject to a legal hold (subpoena, regulator request, active litigation), the Information Security Lead places the record on hold by:

- Recording the matter, the data scope, and the hold start date in the legal-hold register.
- Excluding the record from automated disposal until the hold is released.

- Releasing the hold once the matter is resolved or the obligation expires; from that point, the normal retention clock applies.

Holds are reviewed quarterly to confirm they are still required.

8. Review and Audit

This Policy is reviewed at least **annually**, and after any of the following:

- A material change to the Taxottic data model or to a third-party processor.
- A change in applicable law (US federal or state, or international where we serve users).
- A relevant security incident.

The Information Security Lead spot-checks compliance at least **quarterly** by sampling deletion requests and confirming that production rows are gone and that backup-window propagation has occurred. Findings are recorded in the operations runbook.

9. Exceptions

Any exception to this Policy must be approved in writing by the Information Security Lead and recorded in the operations runbook with a justification, scope, and expiry date. Exceptions are reviewed at the next quarterly compliance check.

10. Contact

Questions, deletion requests, or audit inquiries: [**privacy@taxottic.com**](mailto:privacy@taxottic.com).

Information Security Lead, Techno Optics LLC.